



SENTINELGATE

Adaptive Rate-Limiting & Abuse Detection API Gateway

Next-generation API shield combining distributed Redis Token Buckets with live Machine Learning diagnostics.

The Vulnerability of Static Rate Limits

Why Traditional Gateways Fail

Static rate-limiting tools apply uniform thresholds (e.g. 60 requests/minute) globally to all clients. This architecture creates a critical security mismatch:

- Honest, bursty users are locked out during normal burst load spikes, creating high false-positive rates.
- Malicious actors easily bypass limits using low-and-slow scraping, bot rotations, or DDoS patterns.
- Real-time mitigation usually requires permanent manual IP blocks, leading to massive administrative overhead.

Sophisticated Attack Vectors Addressed:

Aggressive API Scraping

Repetitive, high-volume endpoint traversal aiming to steal proprietary catalog or product data.

Credential Brute-Forcing

Automated authentication attempts returning consistent 401 Unauthorized errors.

Distributed DDoS Bursts

Sudden coordinate traffic spikes intended to degrade microservice availability.

Distributed Token Bucket Architecture

FastAPI & Redis Distributed State

Rather than relying on local memory limits, SentinelGate synchronizes state across multiple gateway nodes globally:

- Gateway Middleware: Lightweight FastAPI proxy nodes verifying requests in sub-milliseconds.
- Distributed Redis Store: Real-time atomic token evaluation using embedded Lua script execution.
- DB Logging Pipeline: Asynchronous SQLAlchemy task execution logging metrics without blocking core API requests.

Distributed Engineering Terms:

🔥 Token Bucket Algorithm

An atomic algorithm tracking available 'tokens' which refill at a set rate. Capacity and refill rate scale dynamically with risk.

🔥 Lua Scripting Atomicity

Executing token calculations inside Redis in a single atomic script to prevent race conditions across parallel requests.

🔥 Resilient Fallbacks

Integrated auto-fallback logic immediately switching to InMemoryRedis and SQLite if production infrastructure drops.

Heuristic Risk Analysis & Isolation Forest ML

Multi-Factor Threat Assessment

Clients are continuously monitored in sliding time windows to compute behavior diagnostics:

- Request Rate (RPM): Current volume compared to safe baseline thresholds.
- Burstiness (Variance): Time delta dispersion tracking machine-like rapid calls.
- Error Rate Frequency: Percentage of unauthorized or broken endpoints reached.
- Endpoint Repetition: Ratio of repeating targets hit, flagging scraping bots.

Machine Learning & Adaptive Control:

Isolation Forest Classifier

Unsupervised machine learning model that isolates anomalous vectors without pre-labeled data. Highly sensitive to novel bot patterns.

Explainable Risk Mapping (0-100)

Heuristic flags combined with ML anomalies yield a score translating to: NORMAL (100 req/m) → MONITORED (60 req/m) → THROTTLED (10 req/m) → BLOCKED (0 req/m).

Operational Advantages & Demo Value

Why SentinelGate Wins

- Automatic Recovery: Risk scores decay dynamically when abuse stops, preventing permanent lockouts.
- Minimal Overhead: In-memory evaluation path maintains a sub-millisecond check latency footprint.
- Real-Time Control Link: WebSocket telemetry pushes logs and metrics instantly to an operational dashboard.
- Fully Deployable Stack: Built-in sandbox simulator generated out-of-the-box (Normal, DDoS, Brute Force attacks).

The Presentation Storyline:

Step 1: Establishing the Baseline

Show legitimate normal traffic passing seamlessly on the dashboard telemetry chart.

Step 2: Triggering the Attack & Defending

Start a DDoS burst. Observe the threat indexes scale dynamically to automatically throttle and isolate the malicious client.

Step 3: Self-Healing

Halt the attack. Observe the risk decaying automatically and restoring client access safely.